MALWARE
detección, eliminación y prevención

NOMBRE _____

01	02	03	04
Tipos de malware	**Síntomas y protocolo de limpieza**	**Análisis: Defender sin conexión y segunda opinión**	**Persistencia y prevención**

01 TIPOS DE MALWARE

CLAVE

Malware es cualquier programa que actúa contra el usuario

La palabra viene de *malicious software*. Lo que importa no es el nombre del tipo, sino **qué hace**: cifrar, robar, espiar, mostrar publicidad o esconderse. Eso decide cómo se limpia y si el equipo se puede volver a confiar.

TIPO	QUÉ HACE	CÓMO LLEGA	SEÑAL TÍPICA
Virus	Se pega a otros archivos o documentos y se ejecuta cuando se abren.	Archivos infectados, documentos con macros.	Archivos que cambian de tamaño o dejan de abrir.
Gusano	Se copia solo de un equipo a otro por la red o por USB, sin que nadie lo abra.	Fallos de seguridad sin parchear, carpetas compartidas, pendrives.	Varios equipos de la misma red con el mismo problema.
Troyano	Se presenta como un programa útil y, por debajo, abre la puerta a otro malware o al control remoto.	Programas «gratis» de webs dudosas, cracks, adjuntos.	Algo instalado hace poco; conexiones de red que nadie explica.
Ransomware	Cifra los archivos y pide un rescate por la clave.	Correo con adjunto, escritorio remoto expuesto, otro troyano.	Extensiones raras en los archivos y una nota de rescate en cada carpeta.
Spyware	Espía: registra teclas, captura pantalla o roba contraseñas y cookies del navegador.	Troyanos, extensiones, programas pirata.	Cuentas a las que entran desde otro sitio.

TIPO	QUÉ HACE	CÓMO LLEGA	SEÑAL TÍPICA
Adware	Muestra publicidad que el usuario no ha pedido.	Instaladores con casillas premarcadas.	Ventanas emergentes, anuncios en webs que antes no los tenían.
Rootkit	Se esconde en lo más bajo del sistema (controladores, arranque) y oculta sus archivos y procesos.	Otro malware que obtiene permisos de administrador.	Difícil de ver: el antivirus se desactiva o el problema vuelve tras limpiar.

Dos categorías que no son virus, pero se limpian igual

CATEGORÍA	QUÉ ES	EJEMPLO
PUP / PUA (programa o aplicación potencialmente no deseada)	Programa que el usuario aceptó sin darse cuenta: barras de herramientas, «optimizadores», cambiadores de buscador. No es ilegal, pero molesta y gasta recursos.	Un limpiador que asusta con «2.000 errores» y pide pagar para arreglarlos.
Criptominero	Usa la CPU o la tarjeta gráfica del equipo para generar criptomonedas para otro.	Equipo con el ventilador a tope y la CPU al 100 % sin nada abierto.

En la práctica un ataque mezcla tipos: un **troyano** entra por un adjunto, descarga un **spyware** que roba contraseñas y, días después, instala un **ransomware**. Por eso, cuando aparece una amenaza, se busca también lo que pudo traer consigo.

PAPEL · EJERCICIO 1 — Escenario → tipo → por qué

¿Qué tipo de malware es?

Para cada escenario, escribe qué tipo de malware sospechas y qué detalle te lo dice.

01 Al abrir el navegador sale un buscador desconocido. El cliente lo cambia y al día siguiente ha vuelto.

→ _____

→ _____

02 Todos los documentos del cliente terminan en `.lockbit` y hay un archivo `README.txt` en cada carpeta.

→ _____

03 El equipo está en reposo, pero la CPU está al 95 % y el ventilador no para.

→ _____

04 Cinco equipos de la misma oficina se infectan en una hora sin que nadie abra nada.

→ _____

05 El antivirus se desactiva solo y, tras limpiar con dos programas, el problema vuelve.

→ _____

06 Un programa avisa de «1.847 problemas graves» y pide 39 € para repararlos.

→ _____

☐ ENTREGA: Hoja entregada al profesor.

02 SÍNTOMAS Y PROTOCOLO DE LIMPIEZA

CLAVE

Lo primero no es el antivirus: es desconectar el equipo de la red

Un equipo infectado puede estar enviando datos, cifrando una carpeta compartida o contagiando a otros. **Se desconecta el cable y el Wi-Fi** antes de hacer nada más. Después se piensa.

SÍNTOMA	PUEDE SER MALWARE…	…PERO TAMBIÉN PUEDE SER
Equipo lento	Criptominero, adware, spyware.	Disco al 100 %, poca RAM, drivers (S16, S18).
Ventanas emergentes y anuncios	Adware, PUP, notificaciones de una web que el usuario aceptó.	Notificaciones permitidas en el navegador: no es malware, se quitan en su configuración.
Página de inicio o buscador cambiados	Secuestrador del navegador (PUP o extensión).	Configuración cambiada por otro usuario del equipo.
Antivirus desactivado que no se deja activar	**Muy sospechoso**: el malware se defiende.	Otro antivirus instalado (Defender se aparta solo).
Archivos con extensión rara y nota de rescate	**Ransomware.** No hay otra explicación.	—
Contactos que reciben mensajes que no enviaste	Cuenta robada o spyware.	Suplantación: alguien usa tu nombre desde otra cuenta.
Programas o extensiones que nadie instaló	Troyano, PUP que vino con otro instalador.	Software que trae el fabricante del equipo.
Mucho tráfico de red sin nada abierto	Malware enviando datos o atacando a otros.	Actualizaciones de Windows, OneDrive sincronizando.

Un síntoma solo no demuestra una infección. Pero **dos o más síntomas que empiezan el mismo día**, sobre todo después de instalar algo o abrir un adjunto, sí justifican el protocolo completo.

El protocolo de limpieza, paso a paso

PASO	QUÉ SE HACE	POR QUÉ
1. Aislar	Quitar cable de red y Wi-Fi. Desconectar pendrives y discos externos.	Corta el robo de datos y el contagio a otros equipos y copias.
2. Documentar	Preguntar qué pasó y cuándo. Fotografiar mensajes y notas de rescate.	Ayuda a identificar la amenaza y a explicarlo después.
3. Copiar los datos	Copiar documentos, fotos y correo a un disco externo. Solo datos: nada de `.exe` ni instaladores.	Si la limpieza o la reinstalación sale mal, los datos están a salvo.
4. Actualizar firmas	Actualizar Defender. Si el equipo está aislado, descargar el paquete de firmas en otro equipo.	Un antivirus con firmas viejas no ve las amenazas nuevas.

PASO	QUÉ SE HACE	POR QUÉ
5. Analizar sin conexión	Examen de Microsoft Defender sin conexión (bloque 03).	Fuera de Windows el malware no está activo y no se puede esconder.
6. Segunda opinión	Otro antimalware a demanda.	Ningún antivirus lo detecta todo.
7. Revisar la persistencia	Inicio, servicios, tareas programadas, navegador, Autoruns (bloque 04).	Lo que se queda en el inicio vuelve a instalar la amenaza.
8. Comprobar y reparar	Reiniciar, repetir un análisis rápido, `sfc /scannow` y DISM si hace falta (S17).	Confirma que está limpio y repara archivos del sistema dañados.
9. Cambiar contraseñas	**Desde otro equipo limpio**: correo, banco, redes. Activar la verificación en dos pasos.	Si había spyware, las contraseñas ya no son secretas.
10. Prevenir e informar	Actualizar, configurar la protección y explicar al cliente qué pasó.	Que no vuelva a ocurrir por la misma puerta.

AVISO

Dos errores que convierten una infección en un desastre

1) **Analizar con el equipo conectado a la red de la oficina.** Mientras tanto, un gusano o un ransomware sigue llegando a las carpetas compartidas y a los demás equipos.

2) **Cambiar las contraseñas desde el equipo infectado.** Si hay un spyware registrando el teclado, el atacante recibe también la contraseña nueva.

Ransomware: qué se hace y qué no

SE HACE	NO SE HACE
Aislar el equipo y comprobar si otros equipos o el NAS también tienen archivos cifrados.	**Pagar el rescate.** No garantiza recuperar nada y financia el siguiente ataque.
Identificar la variante: subir la nota de rescate o un archivo cifrado a ID Ransomware o al Crypto Sheriff de No More Ransom (nomoreransom.org).	Borrar los archivos cifrados. Si algún día sale un descifrador gratuito, se necesitarán.
Buscar en No More Ransom si existe un descifrador gratuito para esa variante.	Conectar la copia de seguridad al equipo infectado «para ver si está bien».
Restaurar desde una copia que estaba desconectada, en un equipo ya limpio o reinstalado.	Negociar o contactar con los atacantes.
Pedir ayuda y denunciar: INCIBE (teléfono 017) y Policía Nacional o Guardia Civil.	Dar por hecho que solo se han cifrado datos: muchos ataques también los roban antes.

03 ANÁLISIS: DEFENDER SIN CONEXIÓN Y SEGUNDA OPINIÓN

CLAVE

Un malware activo puede engañar al antivirus que lo busca

Mientras Windows está arrancado, el malware se ejecuta con él y puede esconder sus archivos o bloquear el análisis. **El examen sin conexión arranca un entorno aparte**, sin cargar el Windows infectado, y analiza el disco desde fuera.

TIPO DE EXAMEN	QUÉ REVISA	CUÁNDO USARLO
Examen rápido	Las carpetas y entradas del registro donde suele esconderse el malware. Minutos.	Revisión diaria; comprobar después de limpiar.
Examen completo	Todos los archivos de todos los discos. Puede durar horas.	Sospecha de infección, primer análisis de un equipo.
Examen personalizado	Solo la carpeta o unidad que se elija.	Un pendrive o una carpeta de descargas.
Examen sin conexión (Defender Offline)	El disco del sistema desde un entorno de arranque propio. Unos 15 minutos.	Amenazas que vuelven, antivirus que se desactiva, sospecha de rootkit.

Cómo lanzar Microsoft Defender sin conexión

- **Seguridad de Windows** → Protección antivirus y contra amenazas → **Opciones de examen**.
- Elegir **Examen de Microsoft Defender Antivirus (sin conexión)** → Examinar ahora. Guardar antes el trabajo abierto: el equipo se reinicia.
- Se ve una pantalla de análisis fuera de Windows. Al terminar, el equipo vuelve a arrancar solo.
- Los resultados están en Seguridad de Windows → Protección antivirus y contra amenazas → **Historial de protección**.

```
REM PowerShell como administrador
Update-MpSignature                  (actualiza las firmas)
Start-MpScan -ScanType QuickScan    (examen rápido; FullScan = completo)
Start-MpWDOScan                     (examen sin conexión: reinicia el equipo)
Get-MpThreatDetection               (amenazas detectadas y qué se hizo)
Get-MpComputerStatus                (estado: protección en tiempo real, firmas…)
```

La segunda opinión

Ningún antivirus detecta el cien por cien de las amenazas. Después de Defender se pasa **otro antimalware a demanda**: uno que analiza cuando se le pide y no se queda vigilando. Así no choca con Defender.

HERRAMIENTA	CÓMO FUNCIONA	OJO
Malwarebytes (versión gratuita)	Se instala y analiza a demanda. Muy bueno con adware y PUP.	Puede ofrecer o activar una prueba de la versión de pago: al instalar, fijarse en qué se acepta.
ESET Online Scanner	Se descarga, analiza y se puede desinstalar al terminar.	Pide conexión para descargar firmas: hacerlo en un momento controlado.
Kaspersky Virus Removal Tool (KVRT)	Ejecutable portátil, sin instalar. Solo analiza y limpia.	Hay que descargarlo cada vez para tener las firmas al día.
Microsoft Safety Scanner	Ejecutable portátil de Microsoft.	Caduca a los 10 días de descargarlo.

AVISO

Dos reglas con los antivirus

1) **Un solo antivirus en tiempo real.** Dos vigilando a la vez se bloquean entre sí y ralentizan el equipo. La segunda opinión se usa a demanda y, si no hace falta, se desinstala.

2) **Descargar siempre de la web oficial**, escribiendo la dirección. Los anuncios de «antivirus gratis» en buscadores son una vía clásica de troyanos.

SOFTWARE · EJERCICIO 2 — En la máquina virtual del aula

Análisis completo en una máquina virtual

El profesor os da una máquina virtual con el archivo de prueba EICAR (un archivo inofensivo que todos los antivirus detectan a propósito) y algunos programas no deseados. Seguid el protocolo y anotad lo que encontráis.

1. Aislad la máquina: desactivad su adaptador de red en la configuración de la máquina virtual.
2. Comprobad que la protección en tiempo real está activa y anotad la versión de las firmas.
3. Lanzad un examen rápido y después el examen sin conexión. En el Historial de protección, mirad qué se detectó, dónde y qué acción se tomó.
4. Pasad un antimalware de segunda opinión que os indique el profesor. ¿Encuentra algo que Defender no vio?
5. Para terminar, dejad activadas la protección contra alteraciones y el acceso controlado a carpetas (bloque 04).

ANÁLISIS	QUÉ HA DETECTADO	RUTA DEL ARCHIVO	ACCIÓN TOMADA
Examen rápido			
Defender sin conexión			
Segunda opinión			
Examen final de comprobación			

☐ ENTREGA: Ficha completada y revisada por el profesor.

04 PERSISTENCIA Y PREVENCIÓN

CLAVE

Si el malware no se elimina del inicio, vuelve

El antivirus borra el archivo, pero una **tarea programada** o una entrada de inicio puede volver a descargarlo en el siguiente arranque. Limpiar es también revisar **todo lo que se ejecuta solo**.

LUGAR	CÓMO SE REVISA	QUÉ BUSCAR
Aplicaciones de inicio	Administrador de tareas (Ctrl+Mayús+Esc) → Aplicaciones de inicio. También Configuración → Aplicaciones → Inicio.	Editor desconocido, nombres genéricos o raros.
Carpeta Inicio	`shell:startup` (usuario) y `shell:common startup` (todos) en Ejecutar.	Accesos directos o scripts que nadie puso.
Registro: claves Run	`HKCU\…\CurrentVersion\Run` y `HKLM\…\CurrentVersion\Run`.	Rutas en `AppData` o `Temp`: no siempre es malware, pero es el primer sitio donde mirar.
Tareas programadas	`taskschd.msc` → Biblioteca del Programador de tareas.	Tareas que lanzan `powershell`, scripts o programas en `AppData`.
Servicios	`services.msc` (S18).	Servicios sin descripción o con ejecutable fuera de `System32` y `Archivos de programa`.
Navegador	Extensiones, página de inicio, motor de búsqueda (tabla siguiente).	Extensiones que nadie instaló, buscador cambiado.

Autoruns: todo lo que arranca, en una sola ventana

Autoruns es una herramienta gratuita de Microsoft (Sysinternals). Muestra cada programa, servicio, controlador, tarea y extensión que se carga solo, en pestañas. Se ejecuta **como administrador**.

ACCIÓN EN AUTORUNS	PARA QUÉ SIRVE
Options → Hide Microsoft Entries / Hide Windows Entries	Ocultar lo que firma Microsoft y quedarse con lo de terceros, que es donde hay que buscar.
Columna Publisher (editor) y Verified	Un programa sin firma o con editor desconocido merece atención.
Options → Scan Options → Check VirusTotal.com	Consulta cada archivo en VirusTotal y muestra cuántos antivirus lo detectan.
Fila en rosa / en amarillo	Rosa: sin datos del editor o firma no verificada. Amarillo: la entrada apunta a un archivo que ya no existe.
Quitar la casilla / Delete	Quitar la casilla **desactiva** la entrada y se puede deshacer. Delete la borra. Primero se desactiva.

El navegador

QUÉ REVISAR	CHROME	EDGE
Extensiones	`chrome://extensions`	`edge://extensions`
Página de inicio y al abrir	Configuración → Al iniciar	Configuración → Inicio, página principal y nuevas pestañas
Motor de búsqueda	Configuración → Buscador	Configuración → Privacidad, búsqueda y servicios → Barra de direcciones y búsqueda
Directivas impuestas	`chrome://policy`	`edge://policy`
Restablecer todo	`chrome://settings/reset`	`edge://settings/reset`

Si el navegador dice **«Administrado por tu organización»** en un equipo doméstico, algún programa ha creado directivas: por eso el buscador vuelve aunque el cliente lo cambie. Se revisan en `chrome://policy` o `edge://policy` y se quita el programa que las creó. Conviene mirar también el **destino del acceso directo** del navegador: si termina con una dirección web, alguien la ha añadido.

```
REM Revisión rápida desde la consola (como administrador)
schtasks /query /fo LIST /v | more        (todas las tareas, con su programa)
reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run
reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Run
netstat -ano                              (conexiones abiertas y el PID que las usa)
type C:\Windows\System32\drivers\etc\hosts   (webs redirigidas)
```

TALLER · EJERCICIO 3 — Por parejas, en la máquina virtual preparada

Caza de la persistencia

El profesor ha dejado en la máquina virtual cinco elementos que se ejecutan solos y que no deberían estar. Encontradlos, decid dónde estaban y quitadlos **sin romper nada legítimo**. Primero con las herramientas de Windows; después comprobad con Autoruns que no queda ninguno.

ELEMENTO	DÓNDE ESTABA	POR QUÉ ES SOSPECHOSO	CÓMO LO HE QUITADO
Elemento 1			
Elemento 2			
Elemento 3			
Elemento 4			
Elemento 5			

☐ ENTREGA: Ficha completada. Autoruns sin entradas sospechosas.

¿Limpiar o reinstalar?

SE PUEDE LIMPIAR	MEJOR REINSTALAR DESDE CERO
Adware, PUP, extensiones y secuestros del navegador.	**Rootkit o bootkit:** el sistema ya no puede vigilarse a sí mismo.
Una amenaza detectada y eliminada que no vuelve tras reiniciar y repetir el análisis.	La amenaza vuelve una y otra vez tras limpiar, o Seguridad de Windows queda rota y no se repara.
Un troyano detectado pronto, sin señales de robo ni de control remoto.	Ransomware o control remoto: no se sabe qué más dejó el atacante.

Reinstalar es **formatear y reinstalar Windows desde un medio limpio**, no volver a un punto de restauración: el malware puede estar también en él (los puntos de restauración y las imágenes se ven en S20). Los datos copiados en el paso 3 se analizan con un equipo limpio antes de volver a abrirlos.

Prevención: lo que se deja configurado

PROTECCIÓN	DÓNDE SE ACTIVA	QUÉ EVITA
Protección contra alteraciones	Seguridad de Windows → Protección antivirus y contra amenazas → Administrar la configuración.	Que un programa desactive Defender o cambie su configuración.
Acceso controlado a carpetas	Protección antivirus → Protección contra ransomware → Administrar protección contra ransomware.	Que programas no autorizados cambien Documentos, Imágenes, Escritorio… Freno al ransomware.
Bloqueo de aplicaciones potencialmente no deseadas	Control de aplicaciones y del navegador → Protección basada en reputación.	Que se instalen PUP y descargas con mala reputación.
Actualizaciones y cuenta estándar	Windows Update, navegador y programas. Configuración → Cuentas: usuario estándar para el día a día.	Que un gusano entre por un fallo ya parcheado o que cualquier programa se instale como administrador.
Copias de seguridad desconectadas	Disco externo que se desconecta al terminar, o copia en la nube con historial de versiones.	Perderlo todo con un ransomware.

AVISO

Acceso controlado a carpetas puede bloquear programas legítimos

1) Si al activarlo un programa de confianza no puede guardar en Documentos, **no se desactiva la protección**: se añade ese programa en «Permitir una aplicación a través del acceso controlado a carpetas».

2) Ninguna protección sustituye a la copia de seguridad. La regla 3-2-1: **3 copias, en 2 soportes distintos, 1 fuera de casa** o desconectada.

Casos con trampa

Investigáis, debatís y anotáis vuestra primera respuesta. Después llega la trampa.

CASO 1
Una pequeña empresa llama: los archivos del servidor aparecen cifrados y piden 3.000 € en criptomonedas. El jefe quiere pagar «para acabar antes». ¿Qué le dices y qué haces primero?

CASO 2
Defender elimina un troyano y el cliente quiere irse a casa. Le dices que cambie sus contraseñas y responde que lo hará ahora, desde ese mismo equipo. ¿Le dejas?

CASO 3
Limpias el adware de un portátil y al día siguiente el buscador raro ha vuelto. Los dos antivirus dicen que el equipo está limpio. ¿Dónde miras?

CASO 4
Un cliente quiere instalar tres antivirus a la vez «para estar más protegido». ¿Es buena idea?

☐ ENTREGA: Ficha de casos completada.

Mi ficha de casos

Caso 1 — Qué le digo y por dónde empiezo:

Caso 2 — Por qué sí o por qué no:

Caso 3 — Dónde miro y qué espero encontrar:

Caso 4 — Qué le recomiendo:

RESUMEN

LO ESENCIAL DE HOY

01 Primero se aísla: fuera cable, Wi-Fi y discos externos.

02 Antes de limpiar, se copian los datos. Solo datos, nada de ejecutables.

03 Defender sin conexión analiza el disco con el malware dormido.

04 Segunda opinión: otro antimalware a demanda. Un solo antivirus en tiempo real.

05 Inicio, tareas programadas, servicios y navegador: si no se limpian, vuelve.

06 Ransomware: no se paga. Se identifica en ID Ransomware o No More Ransom.

07 Las contraseñas se cambian desde otro equipo limpio.

08 Rootkit o amenaza que vuelve: formatear y reinstalar, no seguir limpiando.

09 Los 5 pasos ante un equipo infectado

1	2	3	4	5
Aislar	**Copiar los datos**	**Analizar sin conexión**	**Quitar la persistencia**	**Cambiar contraseñas y prevenir**